

Destino Perú

Informe de situación actual del proyecto
Arquitectura · Seguridad · Roles · Frontend · API

Versión producción — Mayo 2026

Repositorio: github.com/ANTHONY109823/destinoperu
Último commit: **648994f** — descargas CSV/PDF manifiesto y ranking
Stack: Blazor WASM + ASP.NET Core API + PostgreSQL (Railway) + Cloudinary

1. Resumen ejecutivo

Destino Perú es un marketplace de turismo peruano con catálogo público de experiencias, reservas con pago Yape/Plin, programa de fidelidad, y paneles operativos para **Super Administrador, administradores de agencia, vendedores y clientes**. Los errores críticos del panel Super Admin (categoría no encontrada y pestañas inactivas) están **corregidos**.

5
Roles de usuario

4
Categorías SA

2
Capas (WASM + API)

CSV/PDF
Descargas activas

Área	Estado	Comentario
API + PostgreSQL	Operativo	Migraciones y seed al arranque en Railway
Super Admin	Operativo	Inicio con gráficos; 4 categorías con socios, ranking, crear agencia
Admin agencia	Operativo	Tours, 5 vendedores, operaciones, asientos bus, manifiesto
Cliente público	Operativo	Carrito, comparar, checkout, fidelidad
Hoteles / Restaurantes / Cafés (público)	Próximamente	Coming Soon; socios sí en panel SA
Seguridad producción	Mejorable	Ver sección 6 — acciones recomendadas

2. Arquitectura y conexiones

2.1 Diagrama lógico

Cliente (navegador) → Blazor WASM → HTTPS JSON + JWT → **DestinoPeruAPI** → PostgreSQL (Railway). Imágenes vía **Cloudinary**. Auth y carrito en `localStorage`.

2.2 Base de datos

La API resuelve la cadena de conexión en este orden:

- `DATABASE_URL` / variantes Railway
- `ConnectionStrings__DefaultConnection`
- Variables `PGHOST`, `PGPORT`, etc.
- `appsettings.json` (solo desarrollo local)

2.3 Frontend → API

Entorno	URL API
Producción (Railway)	<code>https://destinoperu-production.up.railway.app/</code>
Local	Configurado en <code>wwwroot/appsettings.json</code>

CORS: política `AllowAnyOrigin` (adecuada para WASM; conviene restringir al dominio final en producción).

3. Matriz de roles y usuarios

Rol	Función	Rutas principales (Blazor)	API
-----	---------	----------------------------	-----

SuperAdmin	Plataforma: socios, métricas, suplantación	/superadmin/inicio, /superadmin/tours, hoteles, restaurantes, cafes-bar	/api/superadmin/*
Admin	Dueño de agencia	/admin	/api/agency/*
Vendedor	Pagos, inventario, manifiesto	/vendedor	/api/agency/* (sin crear tours)
Agencia	Legacy → migrado a Admin	/partner	Igual que Admin
Cliente	Compras y reservas	/, /carrito, /checkout, /fidelidad	/api/tours, reservas, pagos

3.1 Tipos de socio (PartnerType)

ID	Categoría	Panel Super Admin	Operación completa
0	Agencia (Tours)	Sí	Tours, reservas, manifiesto
1	Hotel	Socios + crear	Catálogo público pendiente
2	Restaurante	Socios + crear	Idem
3	Café / Bar	Socios + crear	Idem

3.2 Cuentas de sistema (seed)

Sembradas al iniciar la API. **No publicar contraseñas en producción** sin rotarlas vía variables de entorno.

Email	Rol	Uso
superadmin@destinoperu.com	SuperAdmin	Panel global
admin@destinoperu.com	Admin	Agencia demo + tours de prueba
demo@destinoperu.com	Cliente	Flujo de compra demo

4. Frontend — módulos y estado

Módulo	Ruta(s)	Estado
Home y búsqueda	/	OK
Detalle tour	/tour/{slug}	OK
Auth	/login, /register	Registro solo Cliente (API)
Carrito / comparar	/carrito, /comparar	localStorage
Checkout / reservas	/checkout, /mis-reservas	OK
Fidelidad	/fidelidad	OK
Super Admin Inicio	/superadmin/inicio	Gráficos + acceso por categoría
Super Admin categorías	/superadmin/tours, hoteles, etc.	Pestañas Socios, Ranking, +Nuevo, Config
Admin agencia	/admin	Equipo, reservas, tours, operaciones, marca
Vendedor	/vendedor	Pagos, manifiesto, inventario
Manifiesto	/manifiesto	Descarga CSV + PDF
Hoteles / Rest. / Cafés público	/hoteles, etc.	Coming Soon

Nota: Los paneles Blazor validan rol en UI; la seguridad real está en la API con JWT y `[Authorize]`.

5. Backend — API principal

Prefijo	Autorización	Funciones
/api/auth	Público	Login, registro (Cliente)
/api/tours	Mixto	Búsqueda pública; CRUD según rol
/api/superadmin	SuperAdmin	Dashboard, partners, ranking, impersonate, suspend
/api/agency	Admin, Vendedor, SuperAdmin	Perfil, tours, reservas, manifest, vendors, cupos
/api/reservations, /api/payments	Autenticado	Reservas y pagos

JWT: HMAC-SHA256, expiración 7 días, claims: `NameIdentifier`, `Role`, `partner_id`, `impersonating`.

6. Seguridad — evaluación

6.1 Controles implementados

- Contraseñas con **BCrypt** (factor 12).
- Registro público forzado a rol **Cliente**.
- Endpoints sensibles con `[Authorize(Roles = ...)]`.
- Suplantación valida vínculo partner/vendedor.
- Swagger solo en entorno Development.
- Actualización de tours valida `PartnerId` del recurso.

6.2 Hallazgos y recomendaciones

Prioridad	Hallazgo	Recomendación
Alta	Header <code>X-Partner-Id</code> priorizado sin validar titularidad	Solo SuperAdmin puede enviar header; Admin/Vendedor usan JWT
Alta	JWT <code>SecretKey</code> por defecto en appsettings	Definir <code>JwtSettings__SecretKey</code> en Railway
Alta	Seed reescribe contraseña de cuentas sistema en cada deploy	Seed condicional en producción
Media	CORS <code>AllowAnyOrigin</code>	Restringir al dominio del Blazor
Media	Token en <code>localStorage</code>	Valorar cookies <code>HttpOnly</code> o sesiones más cortas
Baja	Sin guard de rutas Blazor	<code>AuthorizeRouteView</code> (UX; API ya protege)

7. Descargas y documentos

Documento	Formato	Acceso
Manifiesto de pasajeros	CSV (Excel) + PDF (impresión)	/manifiesto — Admin, Vendedor, SuperAdmin
Ranking por categoría	CSV	Super Admin → pestaña Ranking
Este informe	HTML + PDF	docs/Informe-Situacion-Actual-DestinoPeru-2026.*

8. Correcciones recientes (mayo 2026)

- **Categoría no encontrada:** resolución de ruta ignora `?tab=` en la URI.
- **Pestañas Super Admin inactivas:** corregido `Tab="mainTab"` (literal) → `@bind-Tab="mainTab"`.
- **Dashboard Inicio:** gráficos donut/barra y navegación a categorías con pestaña.
- **Operaciones Admin:** cajas compactas, asientos de bus (total/libres/vendidos).
- **Descargas:** manifiesto CSV/PDF y ranking CSV (commit 648994f).

9. Backlog recomendado

Prioridad alta

1. Corregir validación `X-Partner-Id` en API.
2. Secretos JWT y Cloudinary solo en variables Railway.
3. Seed sin reset de contraseñas en producción.

Prioridad media

1. Catálogos públicos Hoteles, Restaurantes, Cafés/Bar.
2. Modelos específicos por rubro (habitaciones, mesas, tazas).
3. Rate limiting en login/registro.

10. Despliegue y verificación

- **GitHub:** github.com/ANTHONY109823/destinoperu — rama `main`
- **Railway:** redeploy API + Blazor tras cada push relevante.
- **Prueba post-deploy:** login Super Admin → Inicio → Administrar Tours → pestaña Socios; Manifiesto → Descargar CSV.
- **Caché:** Ctrl+F5 si la UI no refleja cambios.